



FLEETLIX · TRUST & SECURITY

App & Data Security

How Fleetlix protects operator, driver and customer data —
the controls we run today, and the ones we do not yet claim.

VERSION

1.0

ISSUED

7 August 2026

CLASSIFICATION

Public



FLEETLIX LTD · Registered in England and Wales
Company number 17331348
66 Paul Street, London EC2A 4NA, United Kingdom
security@fleetlix.com

Contents

This document sets out the security and data-protection controls in place for Fleetlix as at 7 August 2026. Reviewed annually, and on any material change to the architecture. Questions and vulnerability reports: security@fleetlix.com.

01	Scope and purpose	11	Data on the device
02	How Fleetlix is built	12	Driver location and workforce privacy
03	Tenant isolation	13	Use of artificial intelligence
04	Accounts, authentication and roles	14	Sub-processors
05	Data in transit	15	Personal data and UK GDPR
06	Data at rest, and the honest limit of it	16	How the software is built and changed
07	Photographs, signatures and the media gateway	17	Reporting a vulnerability
08	Credentials and secrets	18	Incident response
09	Audit trail and record integrity	19	What we do not claim
10	Availability, backup and recovery	20	Contact

AT A GLANCE

ISOLATION

Enforced by the database

Every table denies by default. One tenant cannot read another's rows even if the client forges its own tenant id.

TRACKING

None

No analytics, advertising or session-recording scripts. The app makes no third-party requests a driver did not ask for.

MEDIA

Encrypted per tenant

Photos and signatures are stored under a key derived per tenant and held by nobody — not even our hosting provider's dashboard.

RESIDENCY

UK and EU

Database in the EU, object storage in Western Europe. Statutory waste records do not leave the region.

1 Scope and purpose

This document describes the security controls that protect data held in Fleetlix. It is written to be read by two audiences at once: the operator deciding whether to trust us with their yard, and the person filling in a supplier security questionnaire on their behalf.

It covers the Fleetlix operations platform — the installable web app at **fleetlix.app**, the server-side API that supports it, and the database and object storage behind both. It covers the data your business puts into that platform: jobs, customers, vehicles, drivers, walk-around checks, weighbridge tickets, waste transfer notes, invoices and the photographs and signatures attached to them.

It does **not** cover your own internal IT, the devices your staff sign in from, or third-party systems you choose to connect. Where a control depends on something only you can do — keeping a phone locked, removing a leaver's account — that is said plainly rather than glossed over.

On the tone of this document

Security pages tend to be written to reassure. This one is written to be **checked**. Where a control has a limit, the limit is stated next to the control rather than left for a questionnaire to uncover — §6 and §19 are the two places where that matters most. We would rather lose a deal on an honest answer than win one on a claim that does not survive a technical review.

2 How Fleetlix is built

A small architecture is a defensible one. Fleetlix is deliberately three moving parts, not thirty.

The app	One installable web application (a PWA) serving every role — driver, yard, office, maintenance, admin. It runs in the browser and installs to a phone home screen. There is no separate driver app to fall out of date and no native binary to sideload.
The API	Server-side functions running at the network edge on Cloudflare. These hold every credential that must never reach a browser: our database service key, payment keys, the statutory-reporting credentials, messaging provider tokens.
The data	A managed PostgreSQL database (Supabase) in the EU for records, and Cloudflare R2 object storage in Western Europe for photographs and signatures. Nothing else stores your operational data.

The security consequence of that shape is that **the database is the enforcement point, not the app**. Access rules are written as PostgreSQL row-level security policies and evaluated by Postgres on every single query. A bug in the user interface, a modified client, or a request crafted by hand with a valid login cannot read data the policy does not allow — because the application is not the thing deciding.

3 Tenant isolation

Fleetlix is multi-tenant: many operators share one system. Keeping them apart is the single most important control we run, so it is enforced in the one place a client cannot argue with.

- **Row-level security is enabled on every table that holds business data, and every table denies by default.** A table with no matching policy returns nothing. Adding a table without a policy fails safe rather than failing open.
- **The tenant is resolved server-side, never accepted from the client.** Policies call a helper function that reads the signed-in user's own tenant from their profile. It lives in a database schema that is not exposed over the API at all, so it cannot be called or spoofed from outside.
- **The rule is applied to reads and writes alike.** Policies constrain both what a query may return and what an insert or update may write, so a client cannot smuggle a row into another operator's account by setting a different tenant id on the way in.
- **Isolation policies are restrictive, not merely additive.** Where a table has several access rules that grant access (staff, driver, customer portal), a separate restrictive tenant rule is combined with all of them. Adding a new way in later cannot accidentally widen the tenant boundary.
- **Every policy names the signed-in role explicitly.** Twenty-six policies had historically been written without that clause, which in PostgreSQL silently defaults to a role set that includes anonymous visitors. They were corrected, and the migration that corrected them ends with a self-check that **fails the deployment** if any policy is ever added that way again.

Verified, not assumed

Isolation is tested by signing in as a real second-tenant administrator and confirming they see zero rows belonging to the first — not by reading the policy and agreeing with it. The same style of test, executed against the live database inside a transaction that is then rolled back, is run for each migration that touches access rules.

4 Accounts, authentication and roles

Signing in

- Authentication is handled by Supabase Auth. **Passwords are hashed with bcrypt and never stored, logged or transmitted in plain text**, and the Fleetlix application never sees a password — it is exchanged directly with the authentication service.
- A successful sign-in issues a **short-lived access token (one hour)** plus a refresh token. A stolen access token stops working within the hour without anyone taking action.
- New staff are added by invitation. The invite is a **one-time link** through which the person sets their own password; nobody at Fleetlix or in your office ever knows it.
- Sign-out is reachable from every screen, on every device size, for every role — a codified release check, not an assumption. Signing out clears the local session **and purges the on-device data caches** (see §11).

What each person can do

Every account holds one primary role, which determines both what they see and what the database will let them touch. Roles are least-privilege by design — a driver has no ability to read your customer list or your pricing, because no policy grants it, not because the screen is hidden.

Role	Intended for	Broadly
Owner	The account holder	Everything, including billing, plan and other administrators
Admin	Office management	Everything operational; can manage staff but cannot remove the last owner
Office	Dispatch and back office	Jobs, customers, invoices, compliance documents
Yard / Weighbridge	Gatehouse and yard staff	Weighbridge tickets, containers, site checks, load issues
Maintenance	Workshop	Vehicles, work orders, defects, parts
Driver	Cab and roadside	Own run sheet, own walk-around checks, own location
Customer portal	Your customers	Read-only: their own jobs and documents. No pricing, no other accounts

- **An account can never be left with no owner.** Demoting, deactivating or deleting the last owner is refused by the database itself, so no route — including a cascading delete — can strand an account nobody can administer.
- **An administrator cannot escalate themselves.** Only an owner may create or promote another owner.
- **Customer portal logins are firewalled at the column level, not just the row level.** A portal user reads through a dedicated server-side path that omits commercial fields entirely; they cannot see your margin on their own job even by querying for it directly. Site-scoped logins additionally see only their own site, and no invoices at all.
- **Administrator “view as” impersonation is recorded.** Where an administrator views the app as another user to support them, the action is written to the audit trail attributed to the real administrator.

5 Data in transit

- **All traffic is HTTPS.** Plain HTTP is redirected and then refused: the site sends a one-year **Strict-Transport-Security** header including subdomains, so a browser that has visited once will not attempt an unencrypted connection again.
- **A strict Content Security Policy is enforced** (not merely reported). Scripts may load only from our own origin; inline script is refused outright. This is the control that turns most cross-site-scripting attempts into a blocked request rather than an incident.
- **The browser’s outbound allow-list is short and deliberate:** our own origin, our database, our map tile provider and the UK postcode lookup. Anything else — an injected tracker, an exfiltration attempt to an attacker’s server — is blocked by the policy.

- **Framing is refused** (`frame-ancestors 'none'` plus `X-Frame-Options: DENY`), so the app cannot be embedded in another site to trick a user into clicking something they cannot see.
- **Device permissions are locked down at the page level.** The camera and location are available only to our own code and only where the feature needs them; microphone, payment API and USB access are switched off entirely.
- Supporting headers: `X-Content-Type-Options: nosniff`, `Referrer-Policy: strict-origin-when-cross-origin`, `Cross-Origin-Opener-Policy: same-origin`, and a `base-uri / form-action` lock that prevents a page from being repointed at another destination.

6 Data at rest, and the honest limit of it

The database is encrypted at rest by the hosting platform, on managed infrastructure with disk-level encryption and no public network route — the only way in is an authenticated connection subject to the policies in §3.

Photographs and signatures get an additional layer. **Each object is encrypted with a key belonging to one tenant alone**, derived cryptographically (HKDF-SHA256) from a master secret and that tenant's identifier. Because the key is derived rather than assigned, there is no key table to leak, no provisioning step that can fail, and an operator who signed up ten seconds ago already has one. One tenant's key tells you nothing about another's.

The practical effect is that the storage provider **holds the bytes but not the key**. It has been verified in production that the hosting provider's own dashboard cannot preview or download an encrypted object — it returns an error. A platform engineer, ours or theirs, cannot idly browse your customers' proof-of-delivery photographs.

What this is not

This is **not end-to-end encryption, and we will not describe it as such**. The master secret is held in our server-side secret store, so anyone able to read that store could derive any tenant's key. It raises the bar considerably; it does not make us blind to your data. True operator-blindness would require the key never to reach a server, which would break the server-side generation of waste transfer notes and proof-of-delivery documents — and would mean a lost key destroyed records you are legally required to keep. That trade was considered and declined deliberately.

7 Photographs, signatures and the media gateway

Object storage has no concept of a tenant. That gap is closed by refusing to expose the storage at all.

- **The storage bucket is private and has no public URL and no custom domain.** There is no address on the internet that serves an object directly. This is the primary control; the encryption in §6 sits on top of it.
- **Every read and write passes through one gateway** that re-checks the caller's tenant and role before touching storage. The rules live in a single shared module that is unit-tested, so a photograph's visibility is a tested rule rather than a per-screen decision.
- **The gateway authorises with the caller's own session token, never with our master database key.** This is deliberate: a master key on a route that runs for every image request would turn a single browser-side compromise into a whole-platform storage read. The master key is used only where there is no caller to authorise as — an anonymous payment page, or a signed webhook.
- **Object paths are parsed strictly**, so directory-traversal patterns in a filename are rejected rather than interpreted.
- **Visibility differs by document type, on purpose.** Proof-of-delivery photographs and walk-around photographs are excluded from customer portal reads. Load-issue photographs are not — they are the evidence behind a contamination charge the customer is being billed for, and a customer is entitled to see what they are being charged for.
- **A customer can see their own signature and nothing more.** Where a portal user needs the signature on their own transfer note, the database adjudicates that one object by path — it does not widen the rule for the whole bucket, and a request for another tenant's object is never appealable.

8 Credentials and secrets

- **No privileged credential is ever shipped to a browser.** The database service key exists only as a server-side environment secret. This is a standing architectural rule, and the server-side code is type-checked as a separate project specifically so that a credential path cannot compile incorrectly and ship green.
- **Secrets are per-environment and write-only.** Production and preview hold separate values, and a secret cannot be read back after it is set.
- **Inbound API keys are stored as SHA-256 hashes only.** The raw key is displayed once at creation and never again. Keys are per-tenant, labelled, scoped and individually revocable, so rotating one does not disturb the others.
- **Payment webhooks are verified by signature** before any state is changed. A redirect back from a payment page is treated as a hint, never as evidence — only a signed webhook settles a payment record.
- **Payments settle directly to the operator.** Card processing runs through Stripe Connect against the operator's own Stripe account. Fleetlix never holds customer money and **never stores an operator's Stripe secret key** — only an account pointer that is useless without our own platform credential. Card details never touch Fleetlix systems.

- **The account-linking flow is signed.** The state parameter carried through the payment-provider handshake is HMAC-signed with a ten-minute lifetime and compared in constant time, so it cannot be used to attach someone else's payment account to your operation.
- **The media master secret is backed up outside the hosting provider.** If it were lost, every encrypted object would be unrecoverable and no provider could help — so it is not stored solely with the provider that would need it.

9 Audit trail and record integrity

- **The audit trail is written by the database, not the client.** Entries are attributed to the genuinely authenticated user, so an entry cannot be forged by a modified client claiming to be somebody else.
- **Status changes on jobs and invoices are recorded automatically** by database triggers, so a record of a change cannot be skipped by using a different screen or a different route into the system.
- Administrator actions — user creation and deletion, plan changes, impersonation, data exports — are logged and readable in the admin console. The trail is readable by administrators of that account only.
- **Historical records cannot be rewritten by later edits.** Where a document refers to a person, a customer or a site, the name is stored *on the document at the moment of action* as well as being linked. Renaming a customer or removing a driver next year does not alter what a waste transfer note issued last year says.
- **Submitted statutory documents are frozen.** A filed waste data return is snapshotted and cannot be edited; a correction supersedes it rather than overwriting it, so the original filing remains inspectable.

10 Availability, backup and recovery

- The application is served from Cloudflare's global edge network, which absorbs volumetric denial-of-service traffic before it reaches our origin.
- The database runs on managed infrastructure with **automated backups** taken and retained by the database platform.
- **Fleetlix is designed to keep working when the network does not.** Drivers can complete a walk-around check, sign off a job and capture photographs with no signal; the work is stored durably on the device and submitted when signal returns (see §11).
- **The build is the deployment.** The host builds from source on every release; compiled output is never committed. Releases are atomic — a failed build does not partially replace a working one — and a missing asset returns a genuine error rather than a misleading page, which prevents a stale or poisoned response being cached at the edge.
- Server-side code fails **closed**. Where an external dependency is unavailable — a messaging provider, the statutory reporting API, an AI service — the affected action is queued or refused with an explicit status. It is never silently marked as done.

11 Data on the device

A vehicle phone is often shared between drivers and is the most likely thing to be lost. Offline capability is a feature; leaving one driver's data on the screen for the next one is not.

- **Cached data is purged on every identity change.** Signing out, or a different person signing in, clears the cached record and media caches. Without this, the next person to pick up the phone — offline, so no server is consulted — would be served the previous user's rows.
- **The offline queue is scoped to the user who created it.** A check filed by one driver on a shared cab phone can never be submitted under another driver's name.
- **Queued work is never silently discarded.** An item that cannot be submitted is parked and surfaced to the driver with a reason, with retry and discard under their control. A submission that the server legitimately refuses on reconnection — a sign-off that fails a business rule — says so rather than being swallowed.
- Cached data lives in the browser's own storage, protected by the device's operating system and the browser's same-origin rules. **Device-level security remains the operator's responsibility:** a screen lock and device encryption are the controls that matter here, and we cannot supply them.

12 Driver location and workforce privacy

Fleetlix tracks vehicles during a shift so the office and the customer know where a delivery is. It is built so a driver always knows when that is happening.

- **Location sharing cannot start without permission the driver has already granted.** Where the browser reports that location access has not been asked for, the app does not ask and does not call the location API at all.
- **A deliberate stop is respected.** If a driver switches location sharing off, it stays off — it does not quietly resume when the app is reopened. A stop lasts until the next calendar day, on the reasoning that the realistic meaning of "stop" is "not for the rest of today", not "for the next twenty-four hours".
- **The state is always visible.** A pin in the app header shows whether location is being shared, with a live indicator and the state spelled out in words. Nothing about it is covert.
- Location is used for the operational purposes the driver would expect — the dispatch board, the live map and the customer's arrival estimate. It is not used to score or rank individuals.
- **Customer-facing tracking is minimised.** The public tracking page a member of the public receives shows a driver's **first name only**, and only once the job is actually dispatched. A first name makes the knock at the door expected; a surname adds nothing to that.

For the employer

Location data about identifiable staff is personal data, and the lawful basis for processing it belongs to you as their employer. You should tell your drivers it is collected, why, and how long it is kept. We can supply the technical detail you need for that assessment.

13 Use of artificial intelligence

AI has exactly one job in Fleetlix, and it is a narrow one. This section exists because “do you use AI, and what do you send it?” is now the second question on most security questionnaires.

- **One feature, one question.** Where a load carries a European Waste Catalogue code that could be hazardous or not depending on content (a “mirror entry”), the system asks Claude Haiku, from Anthropic, whether the operator’s own notes indicate a competent person should review it.
- **The model never picks the waste code.** Classification comes from a fixed reference table of official codes; a model cannot emit a code that does not exist. The model only ever answers a review question about a code a human already chose.
- **The model can only ever relax an alarm, never raise one.** Every load with a mirror-entry code is flagged for review by rule before the model is consulted. The database refuses to record an AI-sourced alarm at all. Every failure mode — no credential, network error, timeout, refusal, malformed output, low confidence — leaves the flag raised. **There is no failure that produces a false negative.**
- **Absolute-entry codes and notes-free loads never reach the API.** They are answered locally, so most jobs are never sent anywhere.
- **What is sent** is the waste code, the reference description and the operator’s own notes for that load. No customer contact details, no pricing, no photographs, no signatures, no personal data about drivers.
- **Every call is audited** — source, outcome, tokens and latency — and a call that never happened is recorded as such, so the record shows what was and was not sent.
- **There is a per-tenant off switch.** An operator can disable the feature entirely without a code change; the review flag then simply stays raised for a human.
- Data sent to the Anthropic API is **not used to train models**, per Anthropic’s commercial terms.

14 Sub-processors

These are the third parties that may process data on our behalf. Several are engaged only if you switch on the feature that uses them.

Provider	Purpose	Data involved	Region
Supabase	Managed PostgreSQL database, authentication, realtime	All operational records; account credentials	EU
Cloudflare	Application hosting, edge API, R2 object storage	Application traffic; photographs and signatures	Western Europe (storage); global edge
Stripe	Subscription billing, and card payments to the operator	Billing contact and payment details. Card data is handled by Stripe, never by Fleetlix	EU / US (Stripe DPF)

Provider	Purpose	Data involved	Region
Anthropic	Hazardous-waste review assistance (§13)	Waste code and operator notes only	US
Twilio	Customer SMS and WhatsApp notifications	Recipient number and message body	EU / US
Resend	Transactional and customer email	Recipient address and message body	EU / US
DEFRA Digital Waste Tracking	Statutory waste movement reporting	Waste movement records, as required by law	UK
OpenStreetMap	Map tile imagery	Map viewport requests. No customer records are sent	EU
postcodes.io	UK postcode lookup	A postcode. No name or job details are sent	UK

Notable by absence: **there is no analytics, advertising, session-recording or tag-management provider in this list, because there is none in the product.** The application loads no third-party script and makes no request a user did not cause.

We will give reasonable notice of a material change to this list. Write to security@fleetlix.com to be told when it changes.

15 Personal data and UK GDPR

Our role

For the operational data you put into Fleetlix — your customers, your drivers, your jobs — **you are the data controller and Fleetlix is your processor.** We act on your instructions. For your own account and billing data, we are the controller.

Categories of personal data held

- **Staff:** name, work email, role, and — where the feature is used — driving licence and qualification card expiry dates for compliance monitoring.
- **Drivers, additionally:** location while a shift is in progress, walk-around check submissions, and signatures captured on site.
- **Your customers:** business and contact name, address, telephone, email, and the job history that follows from them.
- **Members of the public** receiving a delivery: the site address, and a signature and name where they sign for a load.

Retention

Operational records are retained for as long as your account is active, because waste operations carry statutory duties that outlive any individual job — waste transfer notes must be kept for **two years**, and hazardous waste consignment notes for **three years**. Deleting these on request would put

you in breach, so the platform is built to retain them for the life of the account.

On termination, we will export your data in a machine-readable form on request and then delete it, subject to any period you instruct us to hold it to meet your own statutory obligations. Backups age out on the platform's own rotation.

Data subject requests

A request from one of your customers or staff should be made to you as controller. We will assist you in responding within the statutory period. Where you need to act directly, the platform provides export to CSV and PDF and record-level deletion, subject to the statutory retention above.

International transfers

Operational records are held in the UK and EU. A small number of sub-processors listed in §14 operate from the United States; those transfers rely on the UK Addendum to the EU Standard Contractual Clauses and, where applicable, the provider's Data Privacy Framework certification.

16 How the software is built and changed

- **The whole codebase is statically type-checked**, including the server-side API. Type-checking the API was added specifically because its code — the statutory submitter, the media gateway, the payment endpoints — had been outside the build's checks and could have shipped a genuine fault that only appeared on the one request that reached it. It found five real problems on its first run.
- **Over a thousand automated tests** run against every change, alongside browser-driven end-to-end tests of the critical paths.
- **Database changes are numbered, reviewed and applied deliberately** — never generated automatically at deploy time. Access-control changes are verified against the live database inside a transaction that is then rolled back, so the check is real and the change is not.
- **The database platform's security advisors are run after every schema change**, and findings are fixed rather than accepted. Where a finding is deliberately not actioned, the reason is written down in the repository.
- **Security fixes are documented in the codebase itself**, including the failure that prompted them. A control whose reason is recorded is a control the next engineer does not quietly remove.
- Dependencies are kept current and deliberately few. The application ships no third-party analytics, advertising or tag-management code.

17 Reporting a vulnerability

If you believe you have found a security issue in Fleetlix, please tell us. Email security@fleetlix.com with enough detail to reproduce it — the affected URL or endpoint, the steps, and what you were able to access.

Acknowledgement	Within 2 working days
Initial assessment	Within 5 working days
Fix or mitigation	Prioritised by severity; critical issues are worked immediately
Credit	We are glad to credit you publicly if you would like us to

Safe harbour. We will not pursue legal action against anyone who reports an issue to us in good faith, gives us reasonable time to fix it before disclosing, and does not access, modify or destroy data belonging to anyone else. Please do not run automated scanning that degrades service for operators using the system in the field — a driver in a layby relies on this working.

18 Incident response

If we identify a security incident affecting your data, we will contain it first, then establish what happened and what was affected, then tell you — in that order, and without waiting until the picture is complete to make contact.

- **Notification without undue delay** to affected operators, with what we know, what we do not yet know, and what — if anything — you need to do.
- Where a personal data breach is likely to result in a risk to individuals, **we will support you in notifying the ICO within 72 hours** of you becoming aware, as your processor.
- Credentials and keys are rotated as part of containment. The system is built so that key rotation is survivable rather than destructive — old media keys can be accepted for reading while objects re-encrypt, a design that came directly from an incident in which a key change made objects unreadable.
- A written post-incident summary follows, including what changed to prevent recurrence.

19 What we do not claim

Fleetlix is a young product built by a small team. Overstating our position would be found out in the first serious technical review, so here is the list.

- **We do not hold ISO 27001 or SOC 2.** No certification body has audited us. The controls described here are real and verifiable, but they are ours, not an auditor's.
- **We do not hold Cyber Essentials yet.** It is the certification that makes sense for a business our size and it is on the roadmap; we have not put a date on it here because a date we miss is worse than no date.
- **We have not commissioned an independent penetration test.** Security work to date has been architectural, code-level and verified against the live system by our own team.
- **Media encryption is not end-to-end.** See §6 — we hold the master secret, and we say so.
- **Multi-factor authentication is not yet available.** Sign-in today is email and password with short-lived sessions. MFA is on the roadmap and is the single most requested control we do not have.
- **Compromised-password screening is not yet switched on.** The platform supports it and it is a configuration change, not a build; it is not enabled as at the date of this document.
- **We do not offer a data processing agreement as a click-through.** Ask and we will sign one — it is a conversation, not a form.

Why this section exists

Every item here appears on a standard supplier questionnaire. Answering them before being asked costs us nothing we would not have had to concede anyway, and it means the rest of this document can be taken at face value.

20 Contact

Security and vulnerability reports	security@fleetlix.com
---	-----------------------

Data protection and processing agreements	security@fleetlix.com
--	-----------------------

Sub-processor change notifications	Ask at security@fleetlix.com to be added to the list
---	--

Fleetlix is operated by **FLEETLIX LTD**, registered in England and Wales, company number 17331348. Registered office: 66 Paul Street, London EC2A 4NA, United Kingdom.



DOCUMENT CONTROL

Document	Fleetlix — App & Data Security
Version	1.0
Issued	7 August 2026
Review	Reviewed annually, and on any material change to the architecture.
Classification	Public
Contact	security@fleetlix.com

This document describes the controls in place at the date of issue. It is superseded by any later version published at <https://fleetlix.com/security>. It forms part of no contract unless incorporated by one.

Fleetlix is operated by **FLEETLIX LTD**, registered in England and Wales, company number 17331348. Registered office: 66 Paul Street, London EC2A 4NA, United Kingdom.